

# Revisión Papers semana 3.

Matias Nicolas Toro Hermosilla.

## Software Bill Of Materials Adoption: A Mining Study from GitHub

### ¿Cuál es el problema que se está resolviendo?

La falta de visibilidad en la cadena de suministro de software y los riesgos asociados en seguridad y licencias debido a la integración de un gran número de componentes de software de código abierto y propietario en los productos de software moderno.

En esencia el artículo aborda el problema del entendimiento del estado actual de la adopción del Software Bill of Material (SBOM) en proyectos de código abierto como un medio para abordar los desafíos más amplios de la seguridad y transparencia de la cadena de suministro del software.

### ¿Cuál es la nueva idea que están proponiendo?

El artículo presenta los resultados de un estudio exploratorio de minería sobre proyectos de código abierto apuntando a entender el estado actual de la adopción de SBOM por proyectos de código abierto alojado en GitHub

### Puntos positivos.

1. Se encuentran bien definidas las características de los proyectos que van a ser estudiados. adopción de generación de SBOM trazable, que no sea un fork de otro proyecto para evitar duplicidad, que no tuviera menos de 100 commits, entre otros.
2. Es el primer análisis cuantitativo de adopción de SBOM en proyectos de código abierto. Esto es una contribución significativa ya que complementa estudios cualitativos previos.
3. Suministro de un conjunto de datos seleccionados para futuras investigaciones, crearon y pusieron a disposición del público un conjunto de datos seleccionados sobre proyectos de código abierto que dependen de herramientas para la generación de SBOM

### Puntos Negativos.

1. No especifica la cantidad de repositorios estudiados. A pesar de indicar las especificaciones para poder incluir un repositorio, no especifico la cantidad de repositorios estudiados sino solo los que utilizan alguna herramienta de SBOM
2. Limitaciones de la metodología del estudio. Esto porque se usó el grafico de dependencias de GitHub que los mismos autores reconocen que la exactitud de esta herramienta podría afectar los resultados.

### Trabajo futuro.

Monitoreo continuo de las tendencias de adopción de SBOM, a pesar de que el estudio muestra una tendencia al alza en la adopción, esta sigue siendo baja y puede seguir siendo monitoreada.

Desarrollo de métricas para la evaluación cuantitativa de la adopción de SBOM, esto dado que los autores mencionan una falta de métricas aceptadas para evaluar la adopción de SBOM.

### Calificación. 4/5

Por presentar el primer análisis cuantitativo de proyectos de código abierto para la plataforma de GitHub e identificación de las tendencias de adopción. Sin embargo, el uso del grafico de dependencias para la identificación de proyectos que utilizan herramientas de generación de SBOM podría presentar limitaciones ya que este no es compatible con todos los lenguajes de programación ni herramientas de automatización.

### Puntos de discusión.

1. Análisis del formato de estándares de SBOM.
2. ¿Cómo poder generar consciencia de la importancia de SBOM?

## **On the accuracy of GitHub's Dependency Graph.**

### **¿Cuál es el problema que se está resolviendo?**

Al tratarse de un estudio empírico, mas que resolver un problema, se esta estudiando y evidenciando una situación, la que corresponde a las inexactitudes del grafico de dependencias puede afectar negativamente la efectividad de estudios de SBOM.

### **¿Cuál es la nueva idea que están proponiendo?**

No propone una idea sino más bien una rigurosa investigación y comprensión basada en evidencia de la confiabilidad de una característica fundamental en el ecosistema de desarrollo de software. Esta evaluación y hallazgos que se presentan son cruciales para informar a desarrolladores del grafico de dependencias como a usuarios de esta herramienta

#### **Puntos positivos.**

1. Metodología rigurosa y sistemática para evaluar la precisión del grafico de dependencias, se utilizaron 3 distintos análisis cuantitativos para poder hacer la evaluación.
2. Identificación y cuantificación de imprecisiones es una característica ampliamente utilizada y cada vez más importante. Se provee evidencia de que la herramienta no es completamente exacta para proyectos de Java y Python.
3. Información cualitativa valiosa sobre las razones detrás de las inexactitudes observadas que ofrecen un entendimiento más profundo de los problemas.

#### **Puntos Negativos.**

1. Generalización limitada de los resultados a lenguajes de programación distintos de Java y Python. El estudio solo se enfoca en estos dos lenguajes por su popularidad y compatibilidad de manejo de paquetes (Maven, pip y Poetry)
2. Sensibilidad al tiempo de los hallazgos, dado que el estudio fue minado el 16 de abril del 2023 y los mismos autores indican que al momento de la publicación se pueden haber

resuelto las inexactitudes del grafico de dependencias.

3. Dependencia del web Scraping para recuperar la información del grafico de dependencias de los proyectos.

#### **Trabajo futuro.**

Investigar el impacto de estas imprecisiones en estudios que ya se hayan realizado y que hayan utilizado el grafico de dependencias.

Enfocarse en más lenguajes de programación y el manejo de sus ecosistemas y gestores de paquetes para entender la generalización de los hallazgos.

Contribuir a la mejora del grafico de dependencias de GitHub.

#### **Calificación. 4/5**

El estudio demuestra sus puntos de forma clara y con las evidencias que lo respaldan, independiente de esto, el que solo se hayan analizado dos lenguajes hace que este estudio demuestre un sesgo a pesar de demostrar su punto.

#### **Puntos de discusión.**

1. El impacto en el mundo real de las inexactitudes de grafico de dependencias de GitHub en las practicas del desarrollo de software.
2. Los desafios y complejidades de mantener y rastrear de forma automática información precisa sobre las dependencias en diferentes ecosistemas de software.
3. Futuras mejoras y soluciones posibles para mejorar la precisión del grafico de dependencias de GitHub

## **BOMs Away! Inside the Minds of Stakeholders: A Comprehensive Study of Bills of Materials for Software Systems**

### **¿Cuál es el problema que se está resolviendo?**

El problema que está resolviendo el estudio es la limitada y problemática adopción de SBOM a pesar del importante esfuerzo dedicado a aumentar su conocimiento y desarrollar formatos y herramientas que faciliten su adopción.

### **¿Cuál es la nueva idea que están proponiendo?**

Un estudio empírico comprensivo a través de grupos de accionistas y partes interesadas este presenta las perspectivas de cinco grupos distintos. Además, propone el concepto de especificaciones SBOM multidimensionales en tres dimensiones clave.

#### **Puntos positivos.**

1. Reconoce la importancia y el potencial de las técnicas de SBOM, estas para manejar las dependencias del software, vulnerabilidades y licencias.
2. Esfuerzos continuos hacia la estandarización y las herramientas, haciendo la mención de las 3 mayores definiciones de SBOM como son SPDX y su reconocimiento como estándar ISO, CycloneDX y SWID

#### **Puntos negativos.**

1. El estudio tiene una generalización limitada debido al tamaño reducido de la muestra y además el posible sesgo de autoselección de los participantes, esto dificulta la extrapolación de los resultados a la industria del software en general.
2. El estudio prioriza las perspectivas de las partes interesadas en lugar de analizar en profundidad las características de los SBOM que están siendo utilizados. Esto deja sin poder visualizar el estado práctico y la calidad de los SBOM que se están generando actualmente.

3. Se incluyó a profesionales del área de derecho para poder entender los desafíos no técnicos de los SBOM, pero al ser un solo profesional es demasiado reducido y sujeto a sesgos.

#### **Trabajo futuro.**

Trabajar la incompatibilidad entre los diferentes estándares SBOM (SPDX, CycloneDX, SWID) que es un desafío importante y necesita de un esfuerzo comunitario para poder crear mapeos y herramientas que permitan el paso de un estándar a otro.

Mejorar las herramientas de SBOM especialmente para lenguajes y dominio que no tienen un soporte robusto

Estudiar el impacto de SBOM en la seguridad del software y manejo de vulnerabilidades. Se necesita de mayor investigación para poder cuantificar el impacto actual de la adopción de SBOM en cuanto a la reducción de vulnerabilidades y la capacidad de mitigación de ataque de cadena de suministro.

#### **Calificación. 3/5**

El paper muestra un estudio empírico comprensivo que investiga los desafíos de crear y utilizar SBOM, pero el estudio en sí mismo reconoce las limitaciones acerca de validación externa, además al tratarse de encuestas, estas tuvieron un bajo índice de respuesta.

#### **Puntos de discusión.**

1. Cuáles son los desafíos que obstaculizan la adopción y utilización de SBOM.
2. Soluciones para poder superar los desafíos identificados en el paper.